

CENTRO NACIONAL DE SEGURIDAD DIGITAL

SEGURIDAD DE LA INFORMACIÓN
ISO 27001



Sistemas de Gestión de Seguridad de la Información ISO 27001

1. Importancia de la Norma ISO 27001 en el SGSI de una Empresa
2. Análisis y revisión de la Norma ISO 27001
3. Necesidades y expectativas de la organización: liderazgo y compromiso de la alta dirección

Implementación del SGSI ISO 27001

1. La planificación y la gestión de recursos para el Sistema de Gestión de Seguridad de la Información
2. Evaluación del desempeño y los procesos de Mejora en un SGSI
3. Proceso de implementación de la ISO 27001 en un SGSI

Sistemas de Gestión de Seguridad de la Información ISO 27001



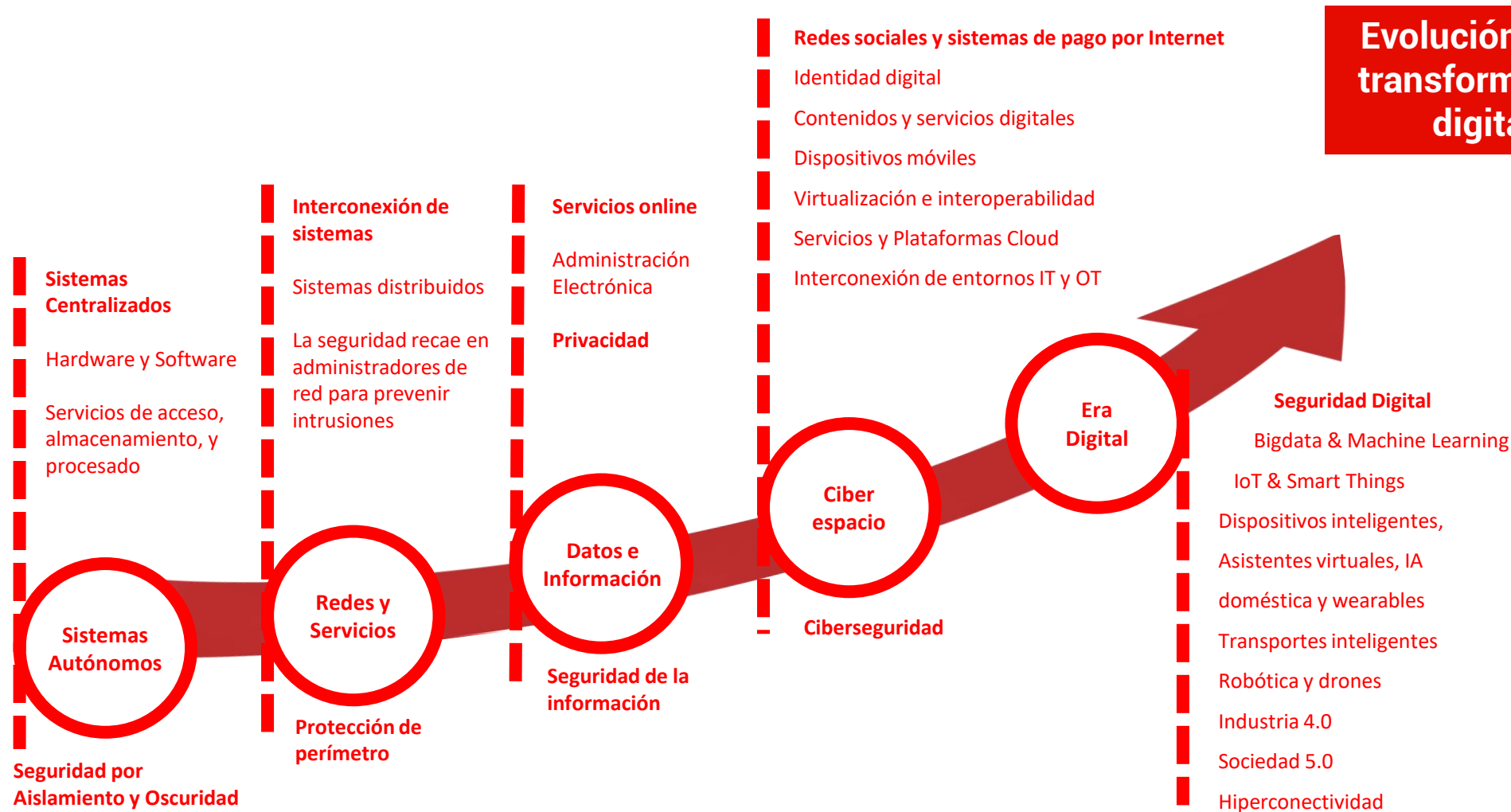
Sistemas de Gestión de Seguridad de la Información ISO 27001

- 1.1 Importancia de la Norma ISO 27001 en el SGSI de una Empresa
- 1.2 Análisis y revisión de la Norma ISO 27001
- 1.3 Necesidades y expectativas de la organización: liderazgo y compromiso de la alta dirección



1.1. Importancia de la Norma ISO 27001 en el SGSI

Nuevas tecnologías, nuevos retos en seguridad



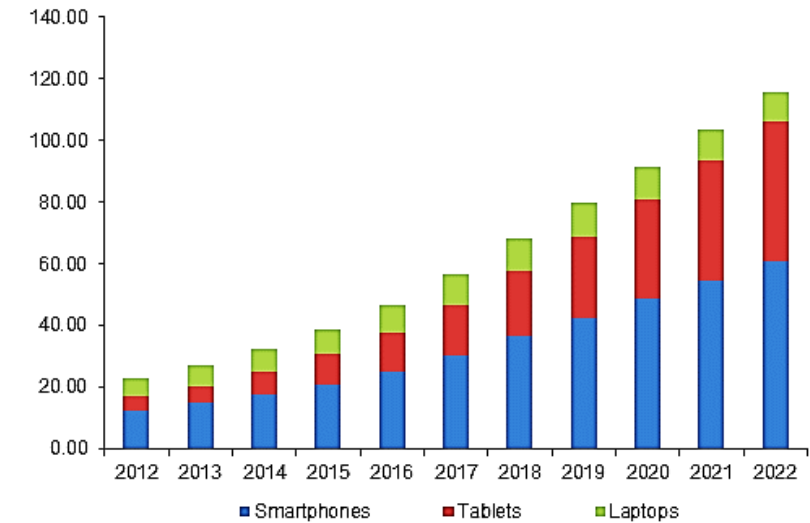
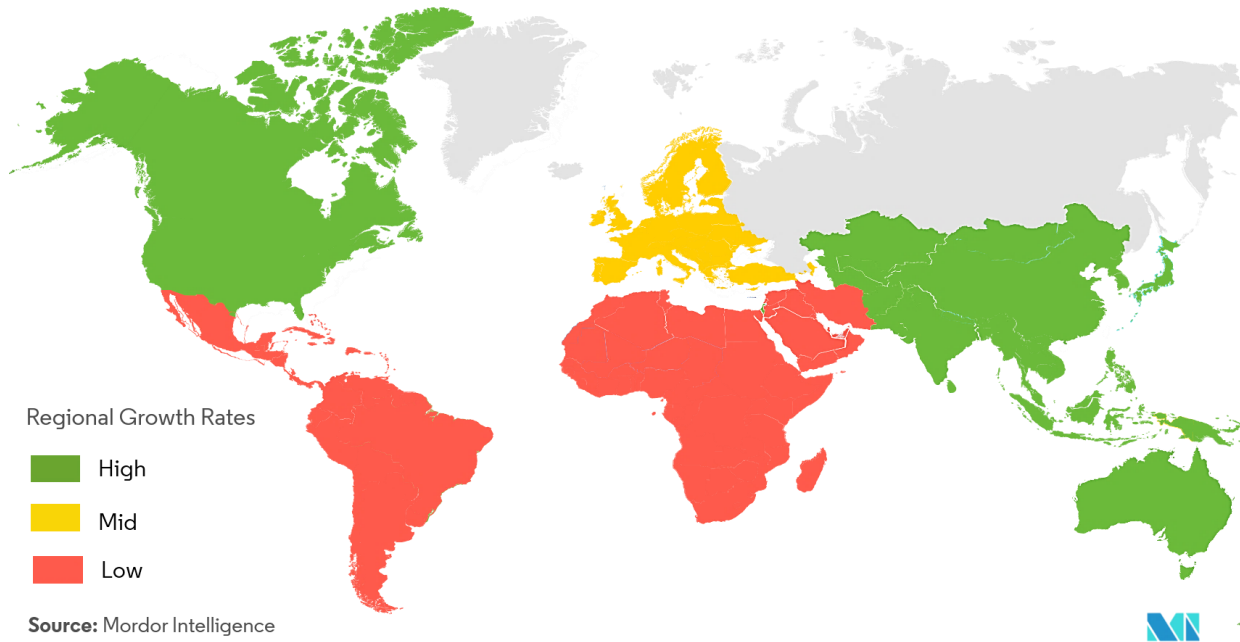
Evolución de la transformación digital

La era digital tiene como principal componente la ruptura de la barrera del mundo físico y el mundo lógico o digital. La aparición, por ejemplo, de los *wearables* permite a las personas llevar consigo más dispositivos que los propios teléfonos móviles.

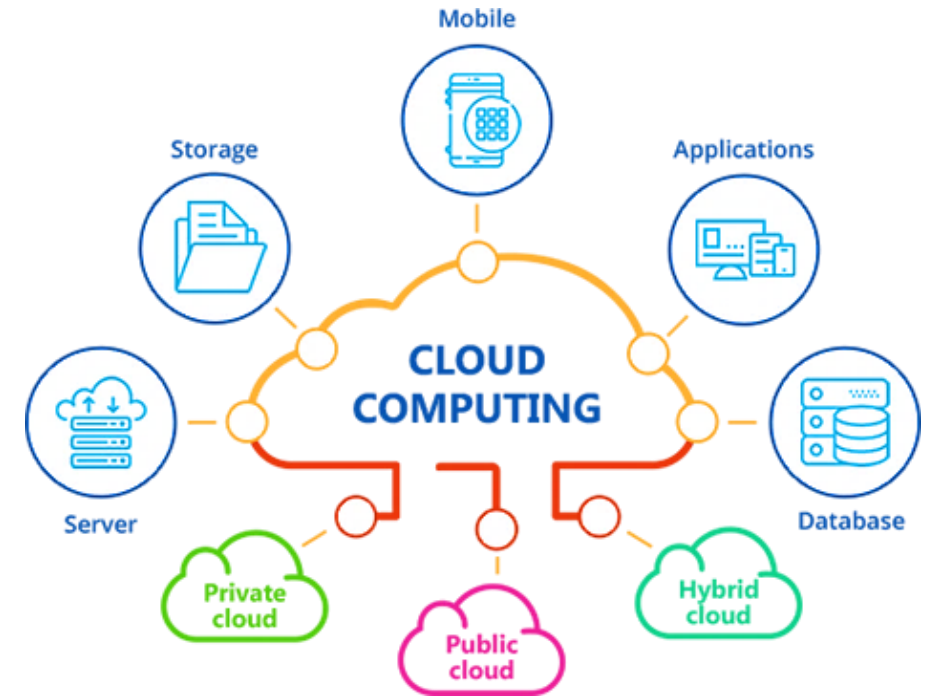
Fuente: Deloitte Cyber Strategy 2020

Nuevas tecnologías, nuevos retos en seguridad

Bring-your-own-Device (BYOD) Market - Growth Rate by Region (2019 - 2024)

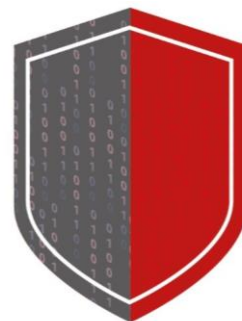


Nuevas tecnologías, nuevos retos en seguridad



Cómo un SGSI garantiza la seguridad continua y mejorada

- ❑ Un SGSI ayuda a gestionar la información en todas sus formas, incluida la información digital, en papel y personal.
- ❑ Ayuda a una empresa a defenderse de los riesgos basados en la tecnología y las amenazas más comunes, como el personal mal informado y los procesos débiles.
- ❑ El enfoque de evaluación y análisis de riesgos reduce los costos invertidos en agregar capas de seguridad.
- ❑ Se adapta a los cambios en el entorno y dentro de la organización para reducir la amenaza de la evolución de los riesgos.



- ❑ Garantiza que la seguridad de la información esté arraigada en el negocio, mejorando la cultura de seguridad organizacional.
- ❑ Se centra en la confidencialidad, integridad y disponibilidad de los datos.
- ❑ Permite a las empresas ser significativamente más resistentes a los ciberataques.
- ❑ La mejora continua, el seguimiento, las auditorías internas y las acciones correctivas garantizan que los controles se mantengan actualizados.

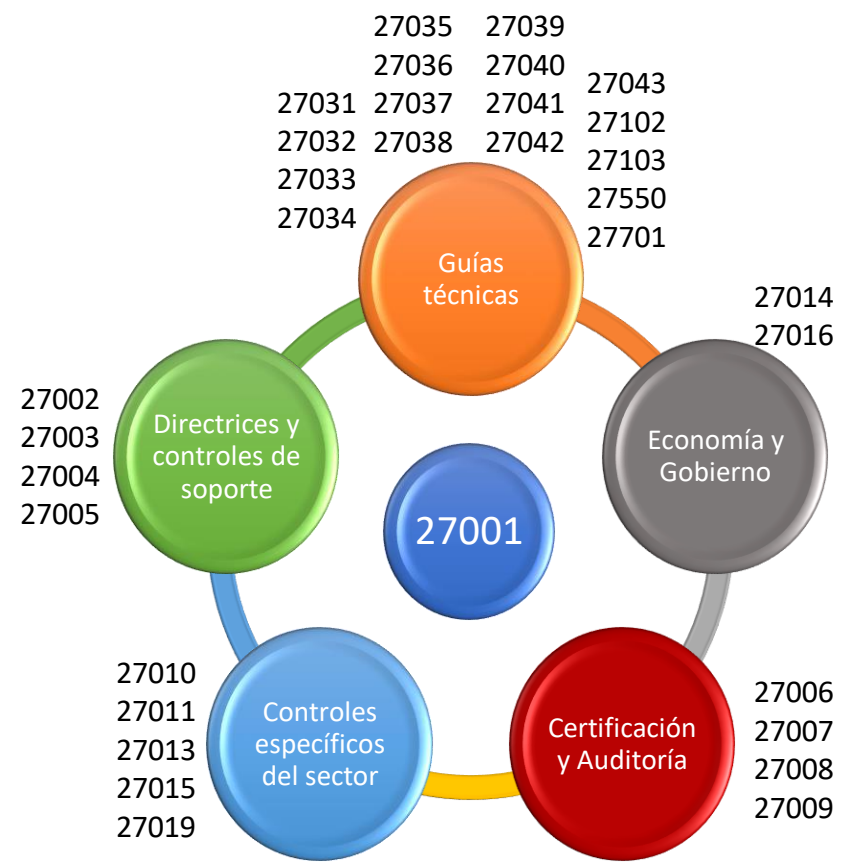
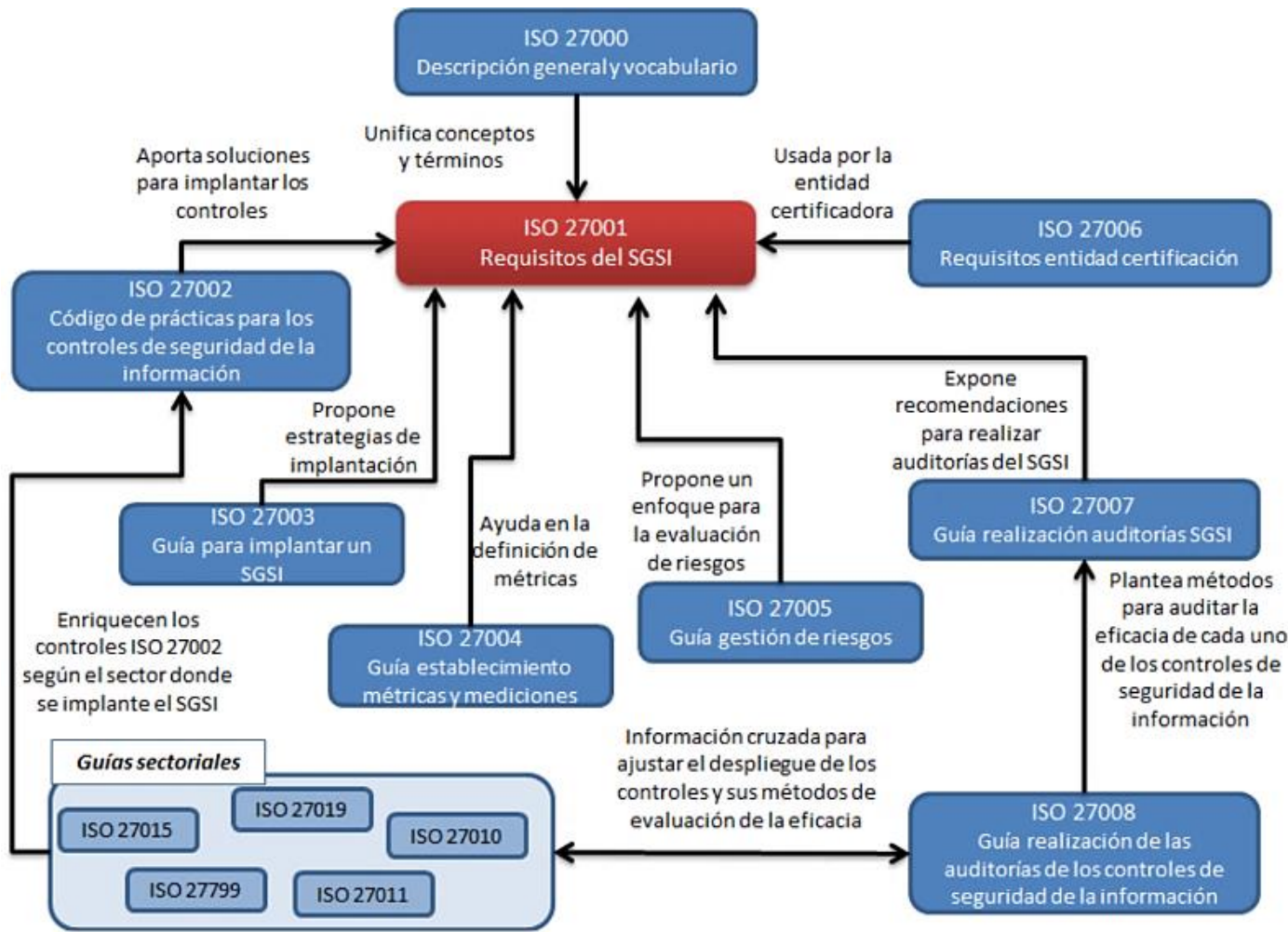
Resultados básicos de la seguridad de la información





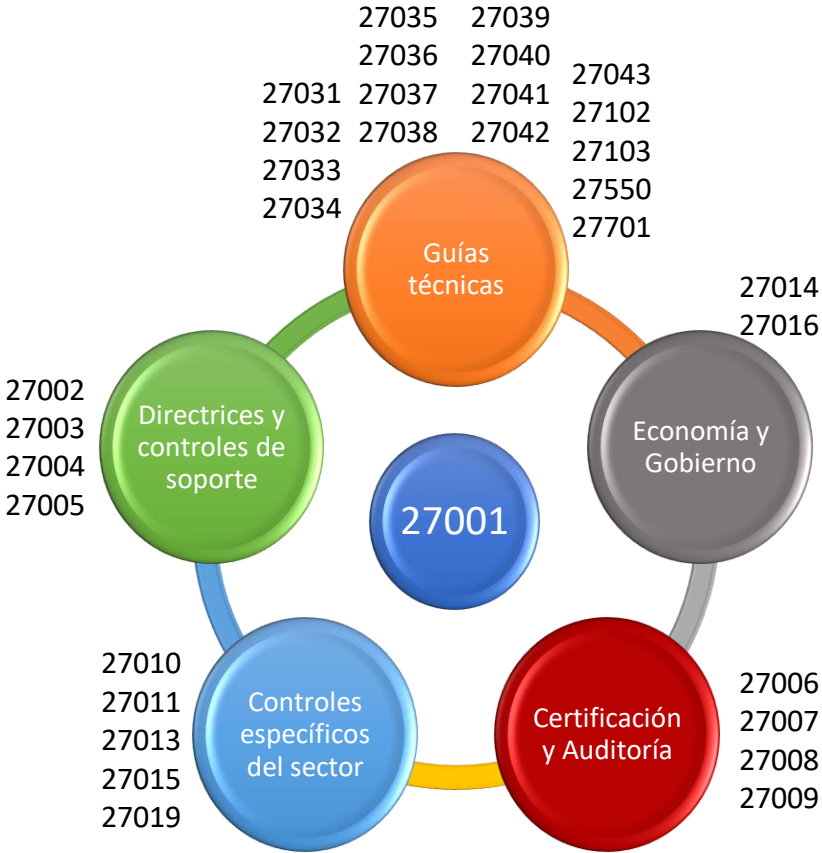
1.2. Análisis y revisión de la Norma ISO 27001

Familia de los estándares ISO/IEC 27000



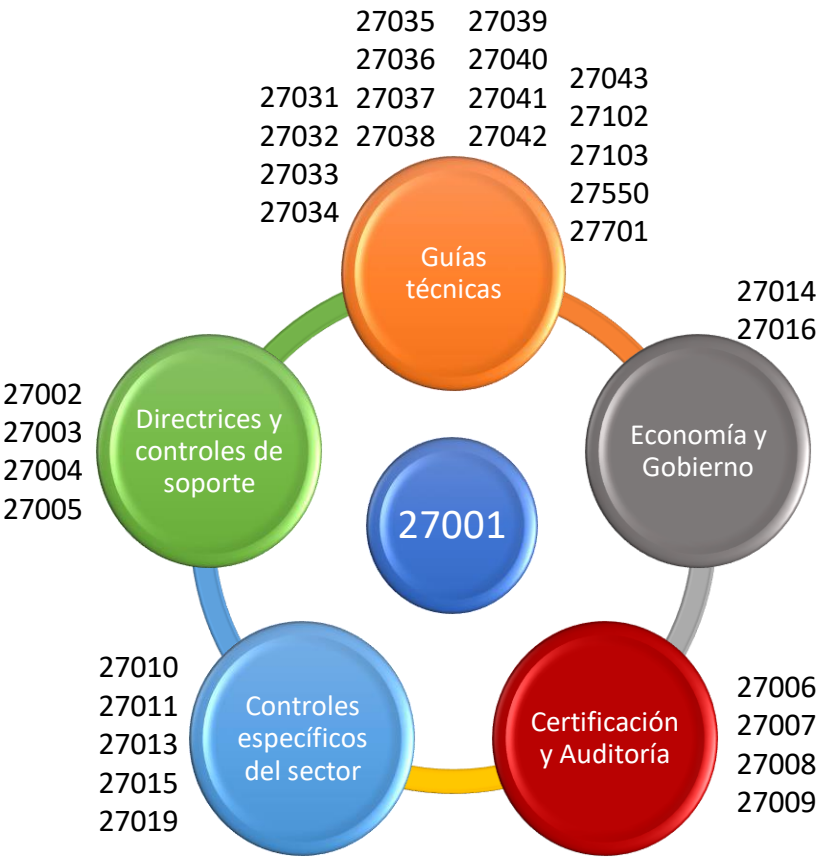
Familia de los estándares ISO/IEC 27000

Certificación y Auditoría		
27006	Requisitos para las organizaciones que realizan auditoría y certificación del SGSI	
27007	Guía de auditoría de un SGSI	
27008	TR: Directrices para los auditores sobre los controles del SGSI	
27009	Directrices sobre el uso y aplicación de los principios ISO/IEC 27001 para organismos de certificación	
27021	Requisitos de competencia para profesionales en Sistemas de Gestión de Seguridad de la Información - ISO/IEC 27021	
27023	Gestión de riesgos de la seguridad de la información	

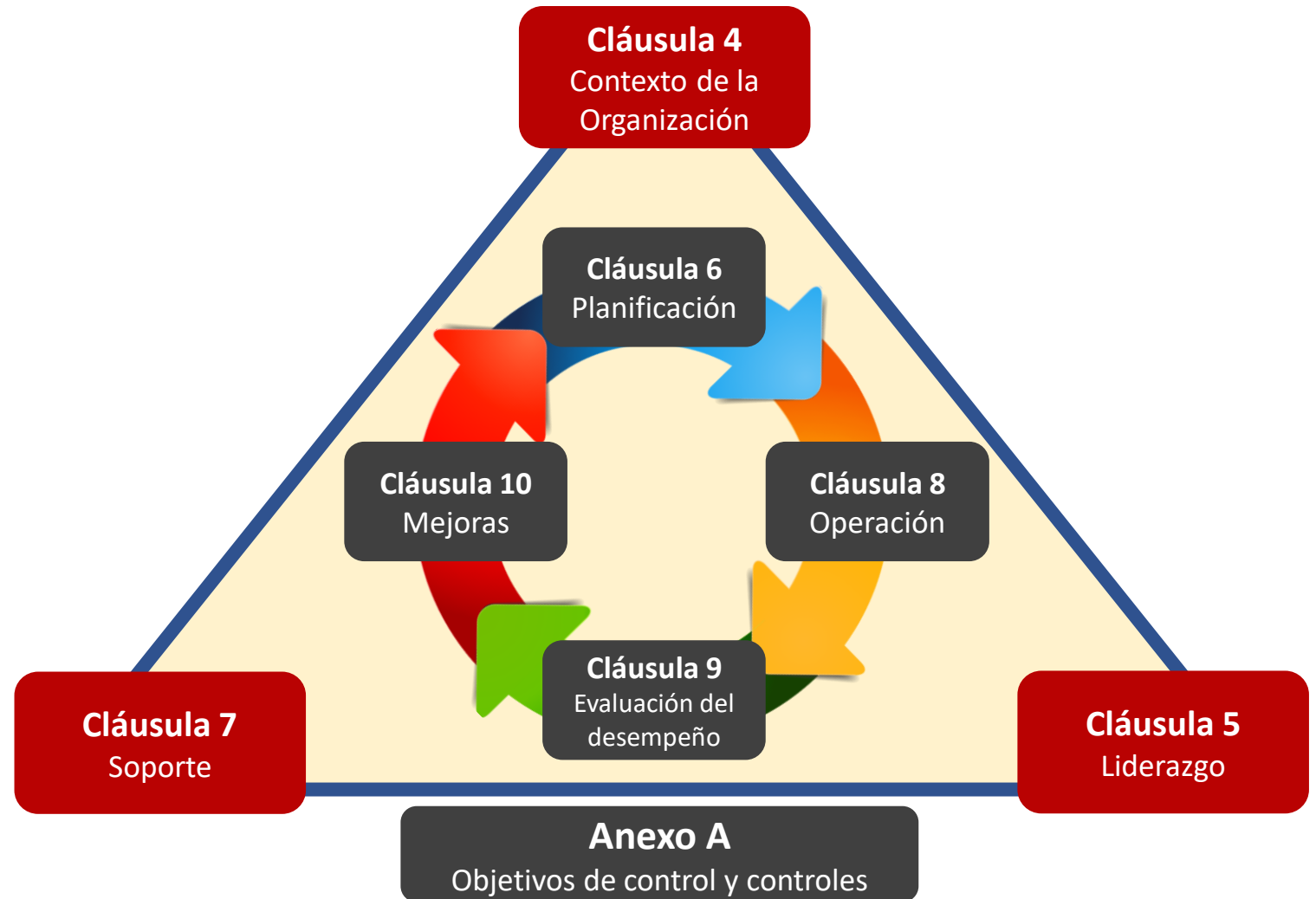
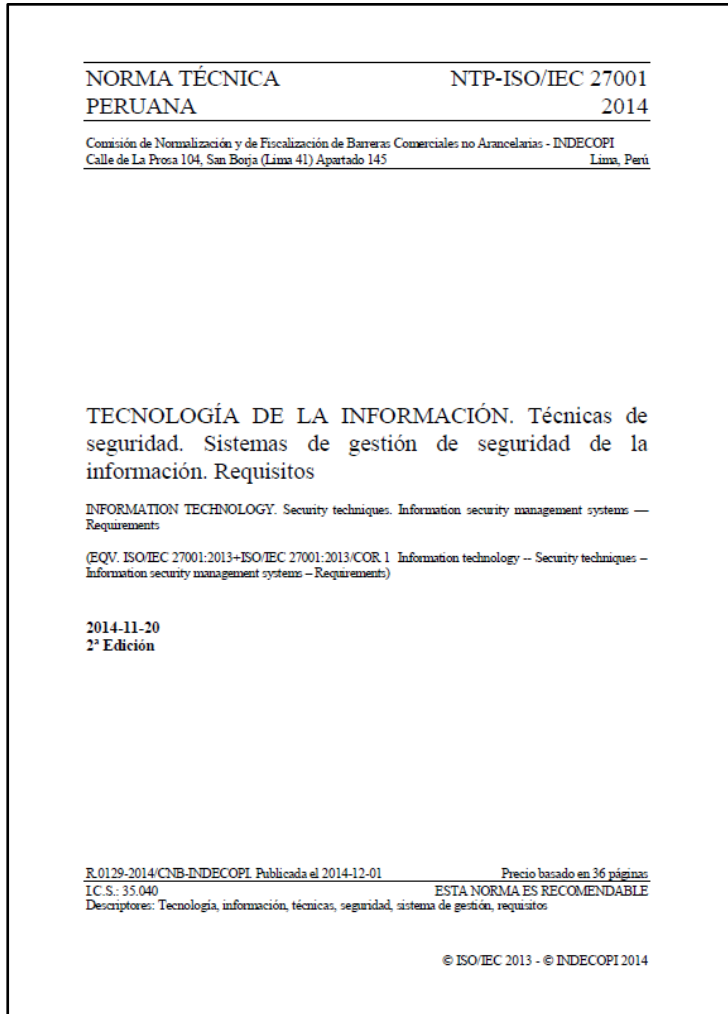


Familia de los estándares ISO/IEC 27000

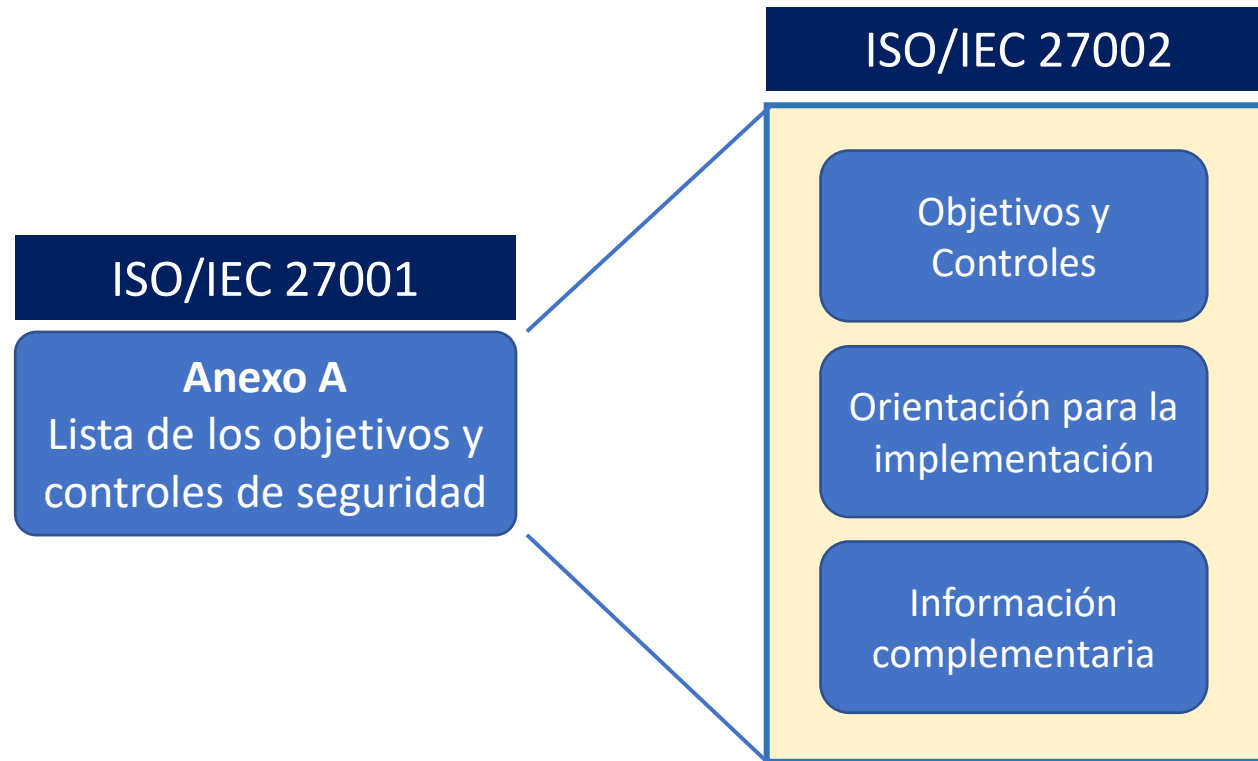
Controles específicos del sector		
27010	Gestión de la SI para comunicaciones inter-sectoriales e inter-organizacionales	
27011	Directrices de gestión de seguridad para las organizaciones de telecomunicaciones basadas en ISO 27002	
27013	Guía para la implementación integrada de ISO/IEC27001 y ISO/IEC20000-1	
27015	TR: Directrices de gestión de SI de los servicios financieros	
27017	Código de prácticas para la seguridad de servicios en la nube	
27018	Código de prácticas para la protección de PII en nubes públicas que actúan como procesadores PII	
27019	TR: Directrices de gestión de SI para sistemas de control de procesos específicos de la industria de servicios públicos de energía	



Estructura de la ISO 27001



Anexo A



PROYECTO DE NORMA TÉCNICA PERUANA
Comisión de Normalización y de Fiscalización de Barreras Comerciales no Arancelarias-
Calle de La Prosa 138, San Borja (Lima 41) Apartado 145

ENTP-ISO/IEC 27002
2016
INDECOPI
Lima, Perú

TECNOLOGÍA DE LA INFORMACIÓN. Técnicas de seguridad. Código de prácticas para controles de seguridad de la información

Information technology — Security techniques — Code of practice for information security controls

2016-XX-XX

"Este documento se encuentra en etapa de estudio, sujeto a posible cambio. No debe ser usado como Norma Técnica Peruana."
I.C.S.: 35.040
Descriptores: Tecnología, información, técnicas, seguridad, sistema de gestión, requisitos

Precio basado en 100 páginas
ESTA NORMA ES RECOMENDABLE

Estructura de las normas

ISO/IEC 27001

- 0 Introducción**
- 1 Alcance**
- 2 Referencias normativas**
- 3 Términos y definiciones**

- 4 Contexto de la organización**
- 5 Liderazgo**
- 6 Planificación**
- 7 Apoyo**
- 8 Operación**
- 9 Evaluación de desempeño**
- 10 Mejora**

Anexo A (normativo) Objetivos de control y controles

Anexo B (informativo) Bibliografía

ISO/IEC 27002

- 0 Introducción**
- 1 Alcance y campo de aplicación**
- 2 Referencias normativas**
- 3 Términos y definiciones**
- 4 Estructura de esta norma**
- 5 Políticas de seguridad de la información**
- 6 Organización de la seguridad de la información**
- 7 Seguridad de recursos humanos**
- 8 Administración de activos**
- 9 Control de acceso**
- 10 Criptografía**
- 11 Seguridad física y ambiental**
- 12 Seguridad de las operaciones**
- 13 Seguridad en las comunicaciones**
- 14 Adquisición, desarrollo y mantenimiento de sistemas**
- 15 Relaciones con los proveedores**
- 16 Gestión de Incidentes**
- 17 BCMS**
- 18 Cumplimiento**

4. Contexto de la organización

¿Cuál es el modelo de negocio?

¿Quiénes son los beneficiados? – Identificarlos

¿Cuáles son los requisitos? Legales, regulatorios, contractuales, de las partes interesadas

(4.1.) Comprender la organización y su contexto

- **debe** determinar los asuntos externos e internos

(4.2.) Comprender las necesidades y expectativas de las partes interesadas => **debe** determinar:

- **Las partes interesadas y los requisitos.**
- requerimientos legales y regulatorios, obligaciones contractuales.

(4.3.) Determinar el alcance del SGSI => debe

- Determinar los límites y la aplicabilidad y
- **debe** considerar:
 - a) los asuntos externos e internos
 - los requerimientos
 - las interferencias**
 - dependencias entre las actividades**

El alcance estará disponible
como información
documentada. (1)

(4.4.) SGSI => **debe** establecer, implementar, mantener y mejorar continuamente un SGSI según los requisitos ISO/IEC 27001

5. Liderazgo

Reúne los requisitos para garantizar la puesta en marcha del SGSI a nivel estratégico y establece las directrices de gestión.

(5.1.) ¿Quién **debe** demostrar liderazgo y compromiso? Para:

Asegurar

- Los **objetivos se establezcan y sean compatibles**
- La integración de los requisitos a los procesos
- Los recursos necesarios se encuentren disponibles
- Se logre los resultados esperados

Comunicar la importancia de la gestión efectiva y del cumplimiento

Promover la mejora continua

Dirigir y apoyar:

- A las personas que contribuyan a la eficacia
- Otros roles de gestión relevantes para demostrar su liderazgo

**Alta
Dirección**

5. Liderazgo

(5.2.) ¿Quién **debe** establecer una Política de Seguridad de la Información?

- Pertinente al objetivo.
- Incluya los objetivos **(6.2)** o el marco de trabajo
- Incluye un compromiso para satisfacer los requisitos y la mejora continua

(5.3.) ¿Quién asegura las **responsabilidades y autoridades**?

Debe ser asignados y comunicados.

- Asegurar que el SGSI cumple con los requisitos de esta norma;
- Informar sobre el desempeño

Alta Dirección
Información documentada (2)

6. Planificación

(6.1) Acciones para Abordar los Riesgos y Oportunidades

debe

Considerar los asuntos (4.1) y los requisitos (4.2)

Determinar los Riesgos y Oportunidades

Asegurar que el SGSI logre resultados esperados.

Evitar o disminuir efectos no deseados
Lograr la mejora continua

(6.1.2) Evaluación de riesgos

debe

Definir y aplicar un proceso
de Evaluación de Riesgos

Planificar

Acciones para abordar los Riesgos
Como:

- Integrar e implementar las acciones en los procesos del SGSI
- Evaluar la eficacia

Establecer y mantener los criterios de Riesgos
Asegurar que las Evaluaciones
Identificar los Riesgos
Analizar los Riesgos
Evaluar los Riesgos

Información
documentada (3)

6. Planificación

(6.1.3) Tratamiento de los riesgos

debe

¿Reducir?

¿Evitar?

Definir y aplicar un proceso de Tratamiento de Riesgos

¿Transferir?

¿Aceptar?

Seleccionar las opciones apropiadas tomado en consideración los resultados de la evaluación de riesgos

determinar todos los controles

Comparar los controles definidos (6.1.3 b) con los del Anexo "A"

Verificar que ningún control necesario fue omitido

Generar una declaración de aplicabilidad

- Controles necesarios 6.1.3 b) y c)
- Justificaciones de las exclusiones

Formular un plan de tratamiento del riesgo

Obtener la aprobación del propietario del riesgo del plan de tratamiento del riesgo

Aceptación de los riesgos residuales

Información
documentada (4)(5)

6. Planificación

(6.2) Objetivos del SI y Planificación

debe

¿Qué se hará?

Establecer los objetivos
en niveles y funciones
relevantes

- **Consistentes** con la Política de SI
- **Medibles**
- **Tomar** en consideración los requisitos de SI y los **resultados** de la evaluación de riesgos y el tratamiento de riesgo
- Ser comunicativos
- actualizados

¿Qué recursos se
necesitarán?

¿Quién será el responsable?

¿Cómo se evaluarán los
resultados?

¿Cuándo se terminará?

Información
documentada (6)

7. Soporte

(7.1) La organización **debe** determinar y proporcionar los **recursos** necesarios

Información
documentada (7)

(7.2) Competencia (**debe**)

- Determinar las competencias de las personas, que afecta su desempeño
- Asegurar que sean competentes
- Cuando corresponda tomar las acciones para adquirir las competencias y evaluar la efectividad
- Retener la información documentada como evidencia

(7.3) Concientización (**debe**)

- **Política de Seguridad de la Información**
- Contribuir a la eficacia, incluyendo los beneficios del desempeño
- Las implicancias por NO cumplir con los requisitos del SGSI

¿Qué comunicar?

¿a quién comunicar?

¿Cuándo comunicarlo?

(7.4) Comunicación internas y externas

- Organización **debe** determinar la necesidad de comunicaciones

¿Qué procesos se verán
afectados por la comunicación?

¿Quién debe comunicarlo?

7. Soporte

(7.5) Información documentada del SGSI

- Información necesaria
- Información documentada definida como necesaria para la efectividad el SGSI

Puede variar de acuerdo a:

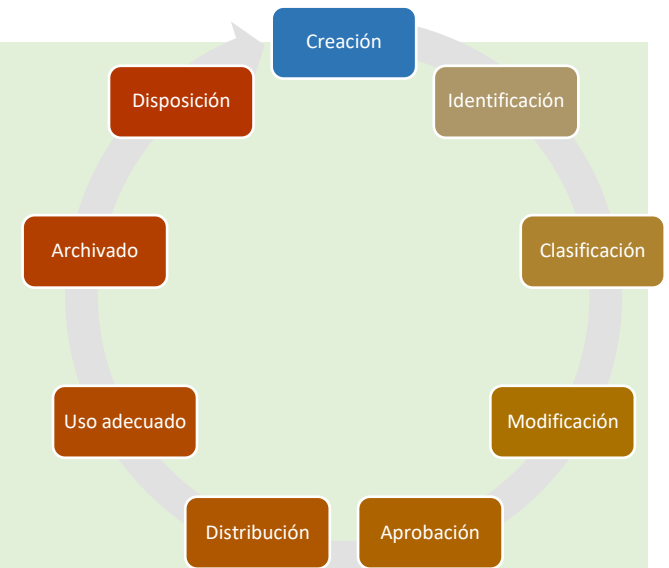
- Tamaño de las organizaciones, tipo de actividades , procesos, productos y servicios
- Complejidad de los procesos y sus integraciones
- Competencia de las personas

(7.5.2) Creación y actualización se **debe** asegurar

- Identificación y descripción (por ejemplo: titulo, fecha, autor o numero de referencia)
- Formato (por ejemplo: idioma, versión de software, gráficos) y medio (por ejemplo: papel, digital)
- Revisión y aprobación para conveniencia y suficiencia

(7.5.3) Control de la información documentada **debe** ser controlada para asegurar

- Esté disponible y apropiada para su uso y cuando sea necesario.
- Debidamente protegida (por ejemplo: de perdidas de confidencialidad , uso inapropiado o perdida de integridad)



8. Operación

(8.1) Control y Planificación Operacional

La organización

debe

- ✓ Planificar implementar y controlar los procesos necesarios para cumplir con los requisitos y para implementar las acciones definidas en (6.1)
- ✓ Implementar los planes para lograr los objetivos definidos en (6.2)
- ✓ Mantener la información documentada hasta que sea necesario y tener la certeza que los procesos que se llevaron a cabo según lo planeado
- ✓ Controlar los cambios planificados y revisar las consecuencias de los cambios no planificados, al tomar cualquier acción para mitigar cualquier efecto adverso
- ✓ Asegurar de que los procesos externalizados se determinan o controlan

8. Operación

(8.2) Evaluación del riesgo

La organización

debe

- ✓ Realizar evaluaciones de riesgo en intervalos planificados o cuando se propongan u ocurran cambios significativos, considerando los criterios establecidos en 6.1.2 a)
- ✓ Conservar la información documentada de los resultados de las evaluaciones de riesgo

(8.3) Tratamiento del riesgo

- ✓ Implementar el plan de tratamiento de riesgo
- ✓ Conservar la información documentada de los resultados del tratamiento del riesgo

9. Evaluación de desempeño

(9.1) Monitoreo, medición, análisis y evaluación

“...se **debe evaluar el desempeño y la efectividad...”**

¿Qué se necesita para monitorear, medir? Incluso los controles y procesos

Los métodos para monitorear, medir, analizar y evaluar, según corresponda y asegurar resultados validos

“...los métodos seleccionados deberían generar resultados comparables y reproducibles para que sean considerados válidos...”

¿Cuando se **debe** llevar a cabo el monitoreo y la medición?

¿Cuándo se **debe** analizar y evaluar los resultados del monitoreo y la medición?

¿Quién **debe** analizar y evaluar estos resultados

¿Quién **debe** monitorear y medir?

Información
documentada (8)

9. Evaluación de desempeño

(9.2) Auditoría Interna

“...se **debe llevar a cabo auditorías internas en intervalos planificados para proporcionar información sobre si el SGSI...”**

- ✓ Cumple con los requisitos de la organización y de la norma ISO/IEC 27001:2013
- ✓ Está debidamente implementada y mantenida, la organización debe
- ✓ Planificar, establecer, implementar y mantener programa de auditoría incluida la frecuencia, métodos, responsabilidades, requisitos de planificación e informes
- ✓ Definir los criterios de auditoría y el alcance para cada auditoría
- ✓ Seleccionar auditores y realizar auditorías que aseguren la objetividad y la imparcialidad del proceso de auditoría
- ✓ Asegurar que los resultados de las auditorías son informados a la dirección o pertinente

Información documentada de programas y los resultados (9)

9. Evaluación de desempeño

(9.3) Revisión por la gerencia

“...la alta dirección **debe** revisar el SGSI en los plazos planificados para asegurar su convivencia, suficiencia y efectividad...”

- Estado de las acciones a partir de las revisiones anteriores
- Cambios en asuntos externos e internos
- Comentarios sobre el desempeño, incluidas tendencias en:
 - ✓ No conformidades y acciones correctivas
 - ✓ Resultados del monitoreo y mediciones
 - ✓ Resultados de auditorias
 - ✓ **Cumplimiento de los objetivos**
- Comentarios de las partes interesadas
- Resultados de la evaluación de riesgo y el estado del plan de tratamiento de riesgo
- Oportunidades para la mejora

Los resultados **deben** incluir las decisiones relacionadas a las oportunidades de mejora y cualquier necesidad de cambios

Información documentada de las revisiones de gestión (10)

10. Mejora

(10.1) No conformidades (NC) y Acciones Correctivas (AC)

- ¿Qué **debe** hacer la organización cuando ocurre una NC?

Reaccionar frente a las NC y si corresponde



Tomar acciones para controlarlo y corregirlo
Encargarse de las consecuencias

- Evaluar la necesidad de acción para **eliminar** las causas de NC y que no vuelva a ocurrir
 - Revisar la NC
 - Determinar la causa de la NC
 - Determinar si existe una NC similar o podría ocurrir

Implementar cualquier acción necesaria



Revisar la efectividad de cualquier AC implementada



Hacer cambios al SGSI si es necesario

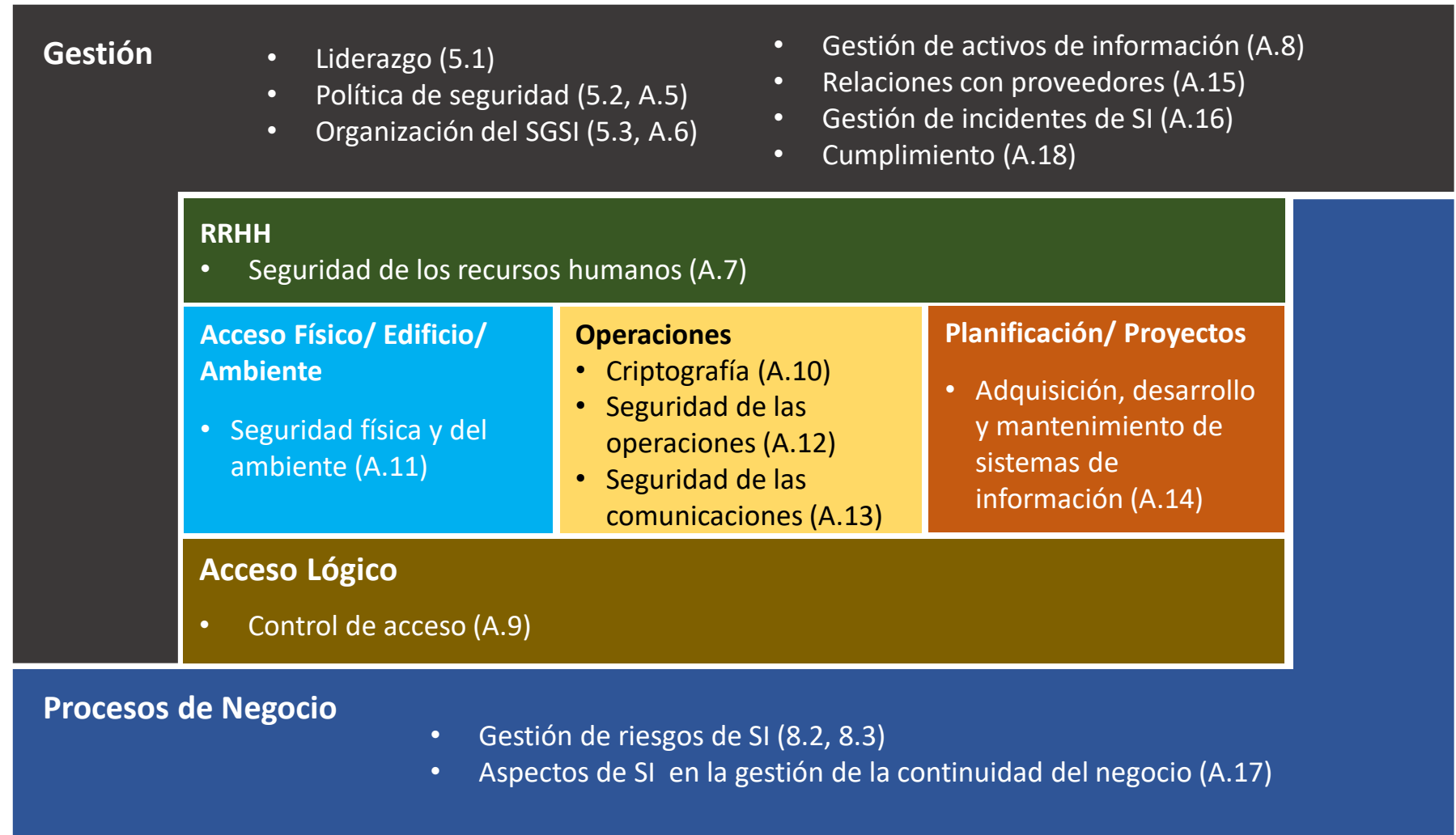
- **Las AC deben ser pertinentes a los efectos de las NC halladas y se debe conservar la información documentada como evidencia de:**

(10.2) Mejora continua

- Se **debe** mejorar de manera continua la convivencia, suficiencia y efectividad del SGSI

Estructura de los objetivos del control

Relación de las cláusulas de la ISO 27001, con los controles del Anexo A.



Dominios ISO/IEC 27002

Estratégicos

5

Políticas de Seguridad

6

Organización de la SI

15

Relación con proveedores

Evaluación y tratamiento de riesgos

Tácticos

11

Seguridad física y ambientes

8

Gestión de activos

18

Cumplimiento

9

Control de acceso

7

Seguridad ligada a recursos humanos

- Seguridad Organizativa
- Seguridad lógica
- Seguridad física
- Seguridad legal

Operativos

16

Gestión de incidentes de SI

17

Gestión de Continuidad del negocio

12

Seguridad en las operaciones

10

Criptografía

13

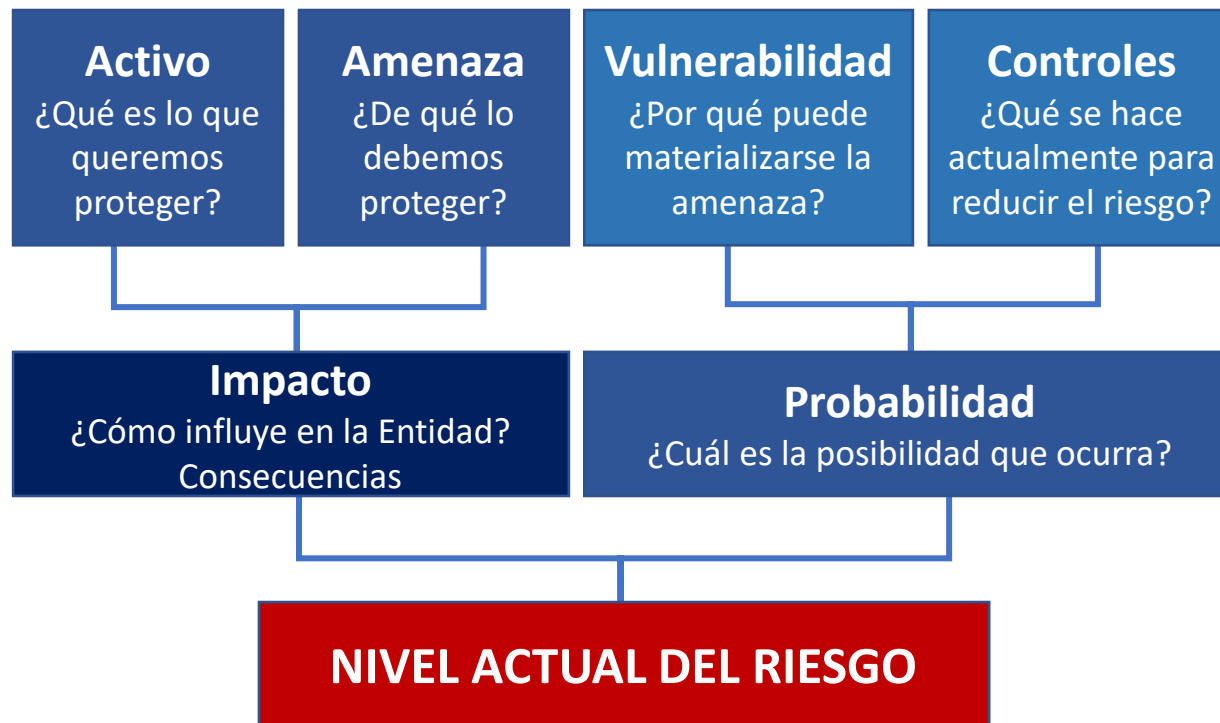
Seguridad en las comunicaciones

14

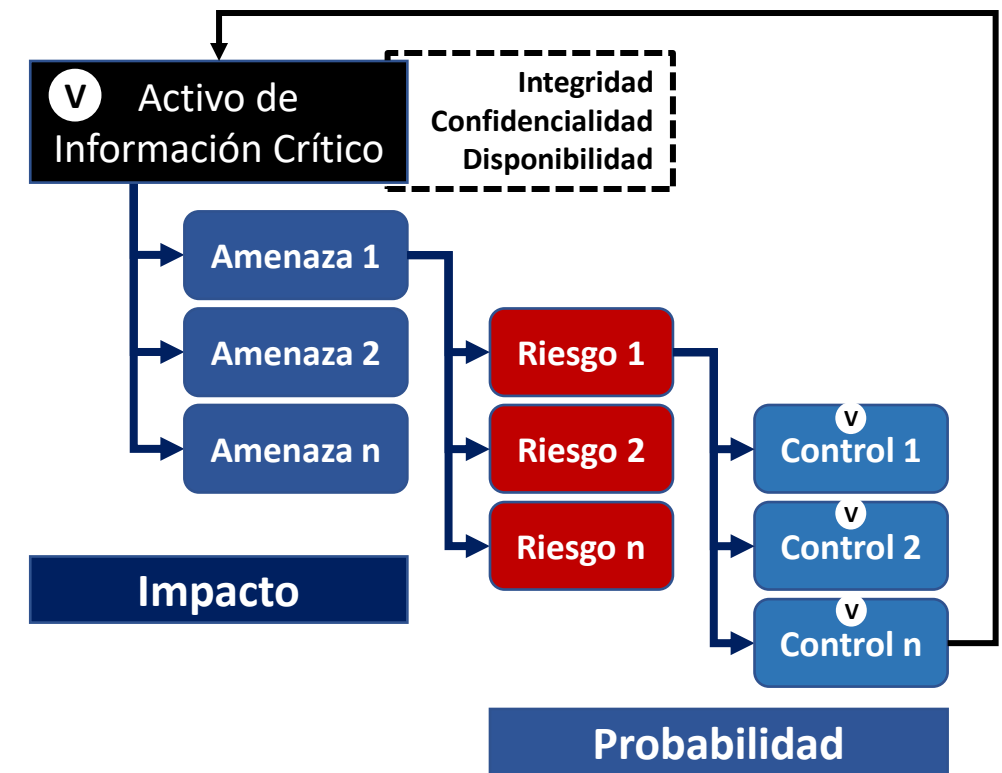
Adquisición, desarrollo y mantenimiento de sistemas

Gestión de los riesgos en activos de información

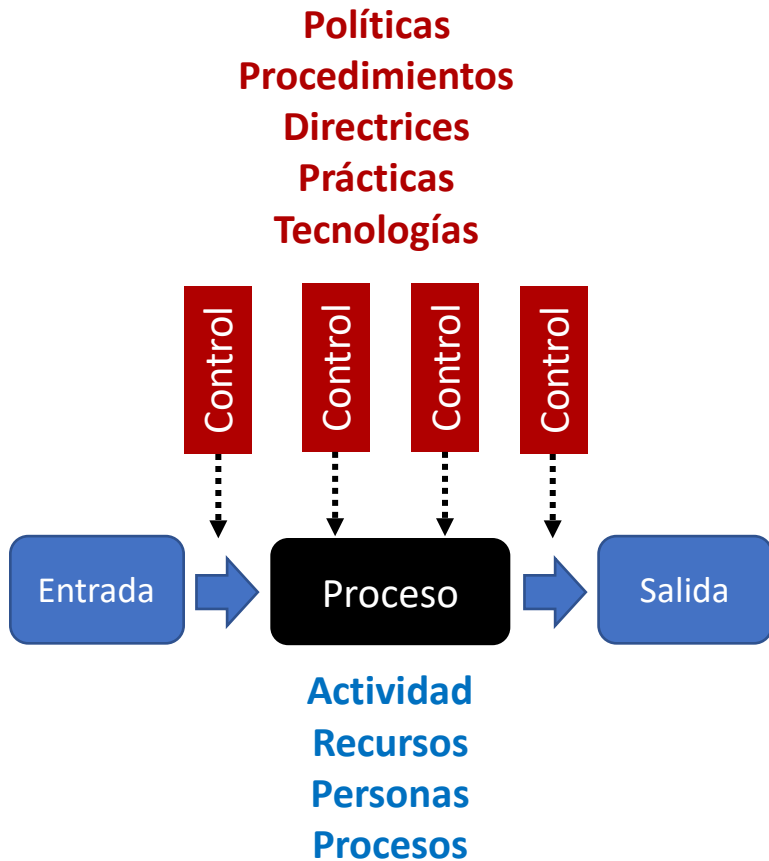
Entendiendo la evaluación de los riesgos en los activos de información y el resultado del nivel actual del riesgo.



Aplicación de los controles y la gestión continua de los riesgos en los activos de información.



Clasificación de Controles de Seguridad de Información



Control Preventivo

- Desalentar o prevenir la aparición de problemas

Control de detección

- Buscar, detectar e identificar problemas

Control correctivo

- Resolver problemas encontrados y prevenir la recurrencia

Clasificación de Controles de Seguridad de Información

Control Preventivo

- Publicar una política de seguridad de la información
- Hacer firmar un acuerdo de confidencialidad
- Contratar sólo personal calificado
- Identificar los riesgos procedentes de terceros
- Segregación de tareas

Control de detección

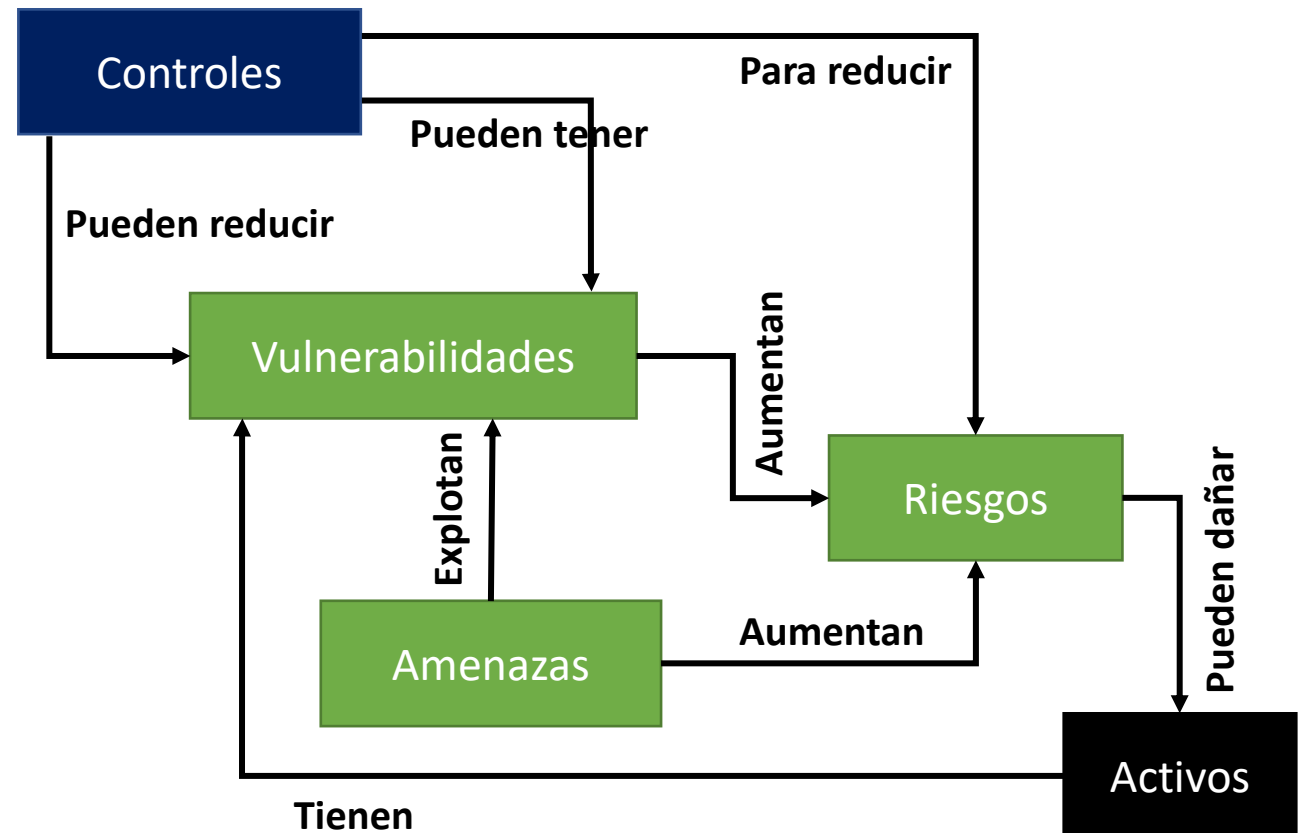
- Supervisar y revisar servicios de terceros
- Supervisar los recursos usados por sistemas
- Activación de la alarma al detectar por ejemplo el fuego
- Revisión de los derechos de acceso de los usuarios
- Análisis de los registros de auditoría

Control correctivo

- Investigación técnica y jurídica (análisis) tras un incidente de seguridad
- Habilitar el plan de continuidad del negocio después de la ocurrencia de un desastre
- Aplicación de parches tras la identificación de vulnerabilidades técnicas

Relación conceptos de seguridad de la información

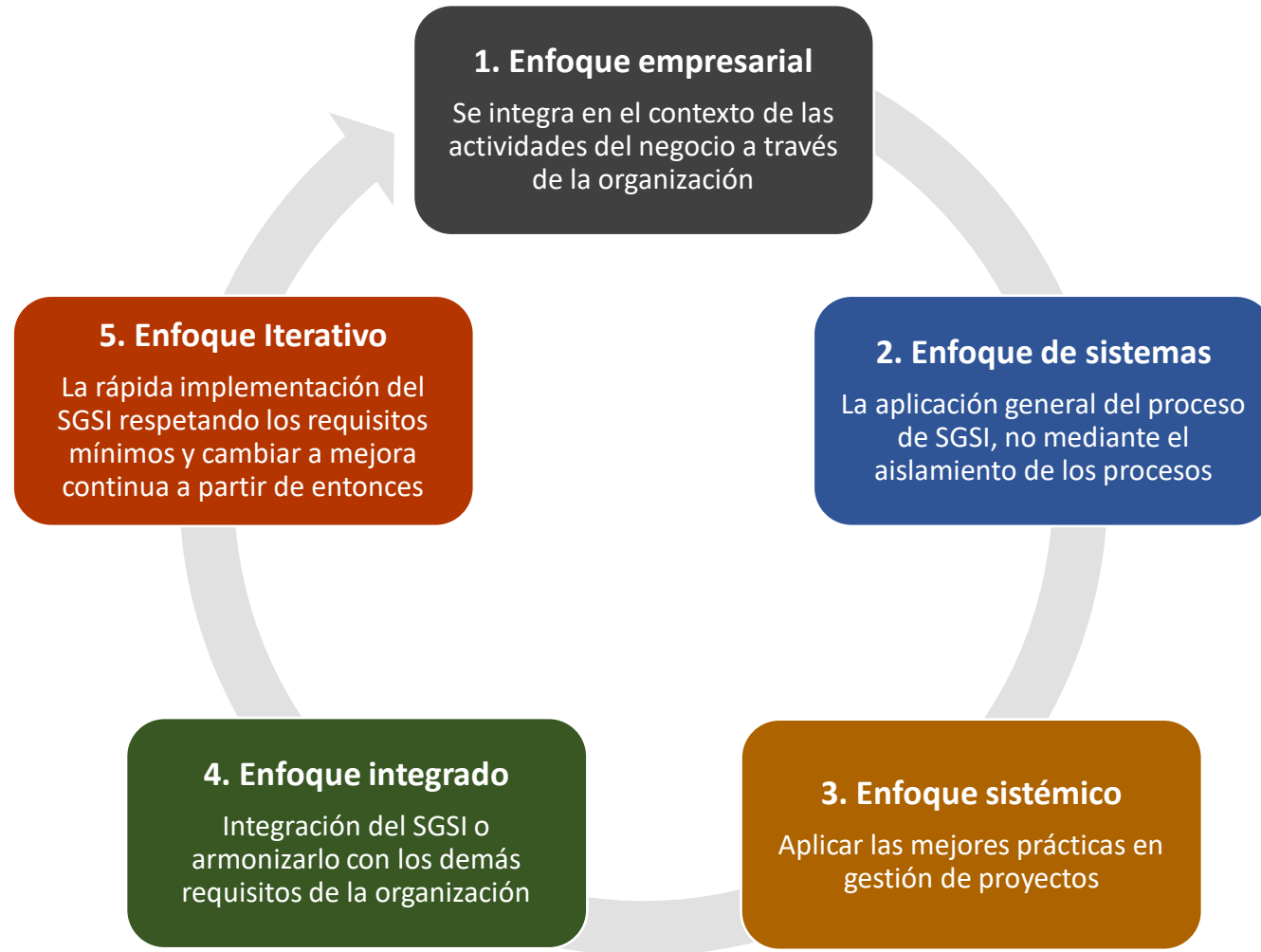
1. **Los activos y los controles** pueden presentar vulnerabilidades que pueden ser explotadas por las amenazas.
2. **Es la combinación de las amenazas y vulnerabilidades** que pueden aumentar el efecto potencial del riesgo.
3. **Los controles permiten reducir las vulnerabilidades.** Una organización tiene pocas alternativas para actuar frente las amenazas. **Por ejemplo:** pueden ser aplicados controles para la protección contra intrusiones, pero es difícil tomar medidas para reducir el número de hackers informáticos en Internet.





1.3. Necesidades y expectativas de la organización: liderazgo y compromiso de la alta dirección

Directrices para el inicio del SGSI



Análisis de brechas (GAP)

- El análisis GAP, permite identificar brechas y debilidades en la gestión de la seguridad de información dentro de las organizaciones, respecto al cumplimiento de la norma ISO 27001:2013.
- Es muy útil para medir el nivel en que el un sistema de gestión de la Seguridad de la Información se encuentra establecido, implementado, operando, monitoreado, revisado, mantenido y mejorado.



Definición de Criterios de Medición



Identificación de Cumplimiento de la Norma



Identificación de Brechas



Análisis de la Medición y Definición de Recomendaciones



Presentación de Informe de Evaluación y Resultados

Análisis de Brecha en las cláusulas ISO 27001

Evaluación del cumplimiento en las cláusulas de la ISO 27001

Documentos cláusulas ISO 27001	NÍVEL 0	NÍVEL 1	NÍVEL 2	NÍVEL 3	NÍVEL 4	NÍVEL 5
Política de Seguridad de la Información	●				Correcto	Optimizado
Documento de definición de ámbito	●					
Procedimiento de Análisis y Gestión de Riesgos	●					
Documento de Aplicabilidad o SOA	●					
Plan de Tratamiento del Riesgo		●				
Objetivos de Seguridad de la Información		●				
Indicadores de Seguridad de la Información	●					
Procedimiento de Gestión Documental	●					
Procedimiento de Gestión de Registros	●					
Provisión de los recursos	●					
Plan de Formación / Awareness de Seguridad	●					
Registros de Formación en Seguridad		●				
Evaluación de necesidades formativas y eficacia	●					
Procedimiento y Plan de Auditorías Internas	●					
Acta de revisiones por la Dirección	●					
Procedimiento de Mejoría Continua		●				
	Inexistente	Planeado	Borrador	Incompleto	Correcto	Optimizado

Análisis de Brecha en los controles ISO 27001

Evaluación del cumplimiento en los controles de la ISO 27001

GRUPOS	ESTADO
A.5 Política de seguridad de la información	33%
A.6 Organización de la seguridad de la información	33%
A.7 Seguridad de los recursos humanos	56%
A.8 Gestión de activos	53%
A.9 Control de acceso	48%
A.10 Criptografía	61%
A.11 Seguridad física y ambiental	58%
A.12 seguridad de las operaciones	75%
A.13 seguridad de las comunicaciones	75%
A.14 Adquisición, desarrollo y mantenimiento de sistemas de información	51%
A.15 Relaciones con los proveedores	36%
A.16 Gestión de incidentes de seguridad de la información	74%
A.17 Aspectos de seguridad de la información en la gestión de continuidad del	12%
A.18 Conformidad	5%

Verificar cumplimiento de ISO 27001

Matriz de verificación de la documentación de requisitos y controles

CHECK LIST ISO 27001:2013				
ACTIVIDAD	DOCUMENTADO?			
	COMPLETO	PARCIAL	NINGUNO	PORCENTAJE
1.1 Requisitos del SGSI	4	3	13	39%
NUMERAL 4	4	0	0	29%
NUMERAL 5	0	3	0	11%
NUMERAL 6	0	0	2	0%
NUMERAL 7	0	0	4	0%
NUMERAL 8	0	0	2	0%
NUMERAL 9	0	0	3	0%
NUMERAL 10	0	0	2	0%
1.2 Controles de seguridad de la información (Anexo A)	32	10	73	32%
POLÍTICAS	14	0	0	100%
6. ORGANIZACIÓN DE LA SEGURIDAD DE LA INFORMACIÓN	2	1	2	50%
7. SEGURIDAD DEL RECURSO HUMANO	3	3	0	75%
8. GESTIÓN DE ACTIVOS	0	3	4	21%
9. CONTROL DE ACCESO	1	0	6	14%
9.3 RESPONSABILIDADES DE LOS USUARIOS	1	0	0	100%
9.4 CONTROL DE ACCESO A SISTEMAS Y APLICACIONES	0	0	5	0%
10. CRIPTOGRAFÍA, CONTROLES CRIPTOGRAFICOS	0	1	0	50%
11. SEGURIDAD FÍSICA Y DEL ENTORNO	1	1	12	11%
12. SEGURIDAD DE LAS OPERACIONES	3	0	11	21%
13. SEGURIDAD DE LAS COMUNICACIONES	2	0	4	33%
14. ADQUISICIÓN, DESARROLLO Y MANTENIMIENTO DE SISTEMAS	3	1	6	35%
15. RELACIONES CON LOS PROVEEDORES	0	0	4	0%
16. GESTIÓN DE INCIDENTES DE SEGURIDAD DE LA INFORMACIÓN	2	0	5	29%
17. ASPECTOS DE SEGURIDAD DE LA INFORMACIÓN DE LA GESTIÓN DE CONTINUIDAD DE NEGOCIO	0	0	4	0%
18. CUMPLIMIENTO	0	0	10	0%

Análisis del Contexto de la organización

Factores Internos	FORTALEZAS	DEBILIDADES
	F1 Existen áreas muy involucradas en implantar una cultura de la seguridad de la información	D1 No se cuenta con el personal y recursos suficientes para cubrir todas las actividades operativas del SGI
	F2 SGI alineado a la estrategia de la organización	D2 Se ha definido una estructura organizativa del SIG que, en su ejecución, no responde adecuadamente a las necesidades del SGI
	F3 SGI es maduro en cuanto a sus procedimientos, metodologías. Se ha pasado por varias auditorías lo cual ha permitido mejoras continuas.	D3 El alcance del SGI no se ha extendido a todos los procesos misionales
	F4 Desarrollos que se llevan a cabo están alineados a estándares internacionales	D4 Existe un desnivel en la concientización del personal en seguridad de información
	F5 Personal calificado y adecuado	
Factores externos	OPORTUNIDADES	AMENAZAS
	O1 Madurez y efectividad del SGI de la Institución respecto a instituciones reguladores de otros países.	A1 Continuo avance de los ataques, ciberdelincuencia y delitos informáticos a nivel mundial
	O2 Aparición de nuevas tecnologías para incrementar la seguridad de los procesos	A2 Incumplimiento con los aspectos de integridad y disponibilidad de la información en los servicios provistos por otras organizaciones
	O3 Relacionamiento con entidades y organizaciones que permiten tener una visión del entorno local y mundial.	A3 Políticas de austeridad
	O4 Normatividad creciente del gobierno peruano en materia de seguridad de información y ciberseguridad.	A4 Indisponibilidad de asistencia técnica de equipos/servidores críticos

SGI = Sistema de Gestión de Seguridad de Información

Política de seguridad de la información y políticas específicas

 **gob.pe** | Centro Nacional de Seguridad Digital

Inicio

Nosotros ▾

Protege tu empresa ▾

Eventos

Aula Digital

Blog ▾

Gestion de incidentes

Sistema de Gestión de Seguridad de la Información

Un SGSI consta de políticas, procedimientos, directrices y recursos y actividades asociados, gestionados colectivamente por una organización, con el fin de proteger sus activos de información. Un SGSI es un enfoque sistemático para establecer, implementar, operar, monitorear, revisar, mantener y mejorar la seguridad de la información de una organización para lograr los objetivos comerciales.

[Conoce más sobre Seguridad de la Información >](#)

Gestión de Seguridad de la Información





Estándares

ISO/IEC 27001

ISO/IEC 27002

ISO/IEC 27003



Plantillas

1. Política de Seguridad de Información

2. Políticas específicas de Seguridad de Información

 **gob.pe** | Centro Nacional de Seguridad Digital

Inicio

Nosotros ▾

Protege tu empresa ▾

Eventos

Aula Digital

Blog ▾

Gestion de incidentes

ISO 27002

Plantillas específicas

Política de Organización de la Seguridad de la Información

Política de Seguridad en los Recursos Humanos

Política de Seguridad en los Activos de información

Política de Uso aceptable de los activos

Política de Control de Accesos digitales

Política de Seguridad física y ambientes

Política de Seguridad en las Operaciones

Política de Seguridad en las Comunicaciones

Política de Adquisición, Desarrollo y Mantenimiento de Sistemas

Política de Relaciones con Proveedores

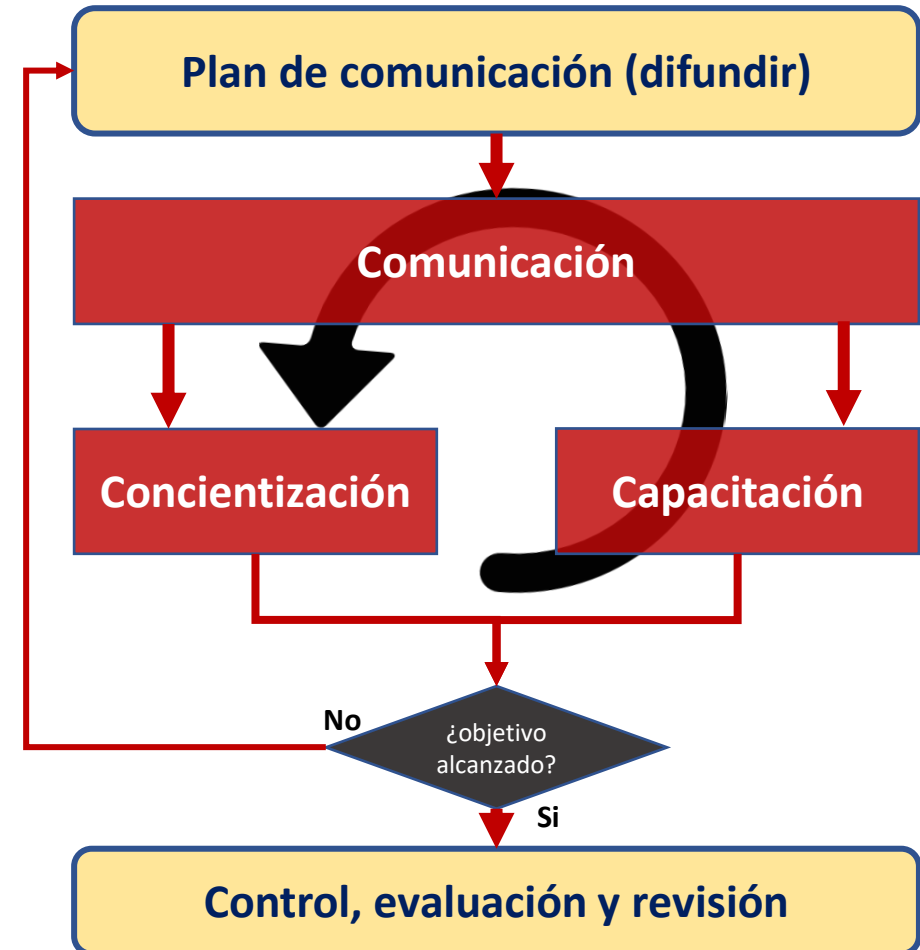
Política de Gestión de incidentes de seguridad de la información

Política de Continuidad de la Seguridad de la Información

Política de cumplimiento

Política de seguridad de la información y políticas específicas

- **La política del SGSI deberá:**
 - Demostrar el compromiso de la Alta Dirección
 - Ser aprobada por la Alta Dirección
- **La política debe ser firmada por una persona de la Alta Dirección, pero el proceso de aprobación puede pertenecer a un comité.**
 - Junta de Directores
 - Consejo de Administración
 - Comité de Gobierno Digital



Riesgos y oportunidades estratégicas SGSI

Riesgo de Alto Nivel		Acciones de Tratamiento
RE1	Incumplimiento con los aspectos de confidencialidad, integridad y disponibilidad de la información en los servicios de los procesos de supervisión y fiscalización de la última milla, es decir con los usuarios finales, ubicados fuera de Lima.	Incluir en la Planificación del SGI, las siguientes actividades: • Programación de las actividades de sensibilización de seguridad de la información a los supervisores y personal de las oficinas regionales de la Institución. • Elaborar indicadores de efectividad de las actividades de sensibilización.
RE2	Indisponibilidad en los portales web utilizados por los supervisados de energía eléctrica, hidrocarburos y gas natural a nivel nacional.	Incluir en la Planificación del SGI, las siguientes actividades: • Asegurar que los gestores de los portales web de los procesos misionales en coordinación con la Gerencia de GSTI, incluyan la actualización de los portales con obsolescencia tecnológica utilizadas por los supervisados a nivel nacional. • Incluir la validación de las funcionalidades y registros de auditoría de accesos de dichas aplicaciones, especialmente en aquellas que fueron desarrolladas hace muchos años.
Oportunidad de Alto Nivel		Acciones de Tratamiento
OE1	Demostrar la madurez y efectividad del SGSI de la Institución respecto a instituciones reguladores de otros países	Programar la adecuación y certificación del SGI basado en la norma ISO 27001:2013, a los procesos misionales.
OE2	La institución cuenta con autonomía financiera	Solicitar los recursos necesarios para asegurar la aplicación y efectividad de los aspectos de seguridad de la información en las oficinas regionales de la Institución, mediante auditorías por lo menos una vez al año.

SGI = Sistema de Gestión de Seguridad de Información

Diferentes Alcances del SGSI

Procesos

El alcance del SGSI se podría establecer, considerando los procesos de la organización que se encuentran inmersos. **Por ejemplo:** Tecnología, desarrollo de sistemas, custodia de documentos.

Organizacional

El alcance del SGSI definido en términos de las unidades organizacionales de la empresa, que participan. **Por ejemplo:** Créditos, Cobranzas, Riesgos.

Tecnología de la Información

El alcance del SGSI definido en términos de los sistemas, servicios e infraestructura tecnológica de la organización totalmente soportado y cumpliendo esas políticas.

** VERSIÓN DE MUESTRA GRATIS **

[logo de la organización]

[nombre de la organización]

DOCUMENTO SOBRE EL ALCANCE DEL SGSI

Código	
Versión:	
Fecha de la versión:	
Creado por:	
Aprobado por:	
Nivel de confidencialidad:	

Estrategias para aliviar los riesgos

Si una organización desea gestionar los riesgos y amenazas a los que se enfrenta su empresa, existen varias soluciones que pueden resultar útiles. La siguiente tabla explica algunas de las soluciones y sus respectivas explicaciones detalladas.

Solución	Explicación
Controles de Seguridad	Para tratar los riesgos de las organizaciones, podemos aplicar los controles de seguridad que se encuentran en ISO 27001: 2013 Anexo A.
Transferencia de riesgos	También existe la posibilidad de transferir el riesgo a otra parte, por ejemplo, poniendo la responsabilidad en una compañía de seguros mediante la compra de la póliza de seguro.
Evite los riesgos	Si una organización descubre que está realizando una actividad que es riesgosa, debe detenerla o encontrar otro método alternativo que no perjudique a la organización.
Aceptar los riesgos	También puede encontrar la forma más concreta de aceptar un riesgo en particular sin dañar la organización. Una forma sería realizar una pequeña inversión que aliviaría la amenaza mejorando la situación.

Gestión de la Seguridad de la Información

